TP2 : sécurité et durcissement

Environnement et installation

Exécution le 28 octobre 2026 sur `tp2-security`, VM Ubuntu 24.04.5 LTS, 2 vCPU et 768 Mio de RAM. Adresse privée : `192.168.77.12`. Le TP1 sert de machine de test réseau, à l'adresse `192.168.77.11`.

```
python3 lab/manage.py start tp2-security
python3 lab/manage.py wait tp2-security
tar -cf - tp2 | python3 lab/manage.py ssh tp2-security 'tar -xf -'
python3 lab/manage.py ssh tp2-security 'sudo bash tp2/setup.sh'
python3 tp2/verify.py
```

Après l'installation, la connexion s'effectue avec `python3 lab/manage.py ssh tp2-security --user alice`. Le compte initial `labadmin` n'est plus autorisé en SSH. Le script peut être relancé par Alice avec `sudo` en fournissant le chemin de sa clé publique autorisée.

SSH

Le fichier complet sshd_config, commenté, remplace `/etc/ssh/sshd_config` après validation par `sshd -t`. L'original reste sauvegardé dans la VM. Il autorise uniquement Alice et exige une clé publique ; root, les mots de passe et l'authentification interactive sont désactivés. Les transferts de ports, d'agent et X11 sont désactivés. `MaxAuthTries 3` limite les essais par connexion.

La configuration effective a été contrôlée par `sshd -T`. Alice s'est connectée avec sa clé ; les connexions root et labadmin ont échoué avec `Permission denied (publickey)`.

Alice dispose de sudo sans mot de passe pour administrer ce laboratoire automatisé. La clé privée reste sur le poste de contrôle, dans `.lab/`, et n'est pas publiée.

Pare-feu

nftables.conf crée une table `inet`, couvrant IPv4 et IPv6. Les chaînes d'entrée et de transfert ont une politique `drop`. Les nouvelles connexions TCP sont limitées à SSH, HTTP et HTTPS. Le bouclage et les réponses aux connexions déjà établies sont acceptés. Une exception UDP ciblée sur la carte `ens3` conserve le DHCP nécessaire à l'accès sortant de cette VM. La sortie reste autorisée.

Pour distinguer un filtrage d'une absence de service, les tests ont démarré trois serveurs temporaires sur 80, 443 et 8088. Depuis le TP1, les connexions sur 22, 80 et 443 ont réussi ; 8088 est resté inaccessible. Une connexion locale a confirmé que le service 8088 écoutait bien. Les serveurs temporaires ont ensuite été arrêtés. Le test sur 443 vérifie l'ouverture TCP, sans déployer de certificat HTTPS dans cet exercice.

Les règles sont chargées par le service `nftables` au démarrage. Export réel du ruleset.

Fail2ban

sshd.local utilise le journal systemd et les actions nftables. Trois échecs dans une fenêtre de dix minutes entraînent un bannissement de dix minutes. Le bouclage et `10.0.2.2`, adresse de gestion du NAT QEMU, sont exemptés pour éviter de perdre le contrôle du laboratoire. Cette exemption doit être adaptée à l'adresse de gestion d'un environnement réel.

Les tentatives SSH d'un utilisateur inexistant depuis `192.168.77.11` ont produit trois échecs reconnus et un bannissement réel de cette adresse. `fail2ban-client status sshd` a affiché cette IP dans `Banned IP list`. Le test a ensuite levé le bannissement pour rendre le laboratoire réutilisable.

Audit

passwd.rules surveille les lectures, écritures et changements d'attributs sur `/etc/passwd`, avec la clé `passwd_watch`. Le fichier est installé dans `/etc/audit/rules.d/` puis chargé par `augenrules --load`.

Une lecture avec `cat /etc/passwd` a produit des événements `PATH` et `SYSCALL`, avec `syscall=openat`, `success=yes`, `exe=/usr/bin/cat` et `key=passwd_watch`. L'identité de connexion `auid=alice` reste visible même lorsque la commande est exécutée via sudo. Extrait réel des événements.

Erreur rencontrée

La première recherche `ausearch` lancée sans terminal via SSH ne retournait aucun événement, alors que le fichier d'audit en contenait. La lecture explicite avec `ausearch -if /var/log/audit/audit.log` a résolu le problème et a été intégrée au script de contrôle.

Résultat

Les quatre services `ssh`, `nftables`, `fail2ban` et `auditd` sont actifs. Les tests SSH, réseau, bannissement et audit ont réussi. Commandes et résultats complets.